

Best Practices to Implement Prior to a Breach

Modes of Learning

For this module, the following modes of learning will be used:

- Interactive Module
- Textbook Readings
- Online Quizzes
- Written Reports

Introduction

Cybersecurity has been defined by the National Institute of Standards and Technology (NIST) as “the process of protecting information by preventing, detecting, and responding to attacks.” Cybersecurity incidents occur frequently and cause disruption to business and damage to reputation.

Cyber incidents can be attributed to three main causes:

1. **Human Error:** this includes employees mistakenly clicking on fraudulent emails, unknowingly downloading malware or transferring funds in response to fraudulent instructions from hackers.
2. **Operational Failure:** this includes systems and technology failure (e.g. failure of hardware, software, or information systems) as well as failed internal processes (e.g. issues in the internal business process which prevents effective implementation of cybersecurity policies) business and potentially costly lawsuits.
3. **Attacks by Cybercriminals:** this category includes intentional and premeditated attacks by cybercriminals, which can include nation-states, crime groups, corporations and hacktivists.

Cyberattacks are common, so organizations need to implement cybersecurity controls before a breach, to prevent or reduce attacks on their data and information systems, and to mitigate the resulting losses of a successful attack.

The best preventative practices focus on three main areas:

- Employee hiring, training and monitoring
- Security considerations of organizational technology
- Insurance and risk management

As you begin this module, please refer to the timeline and make note of any assessments or important dates. If you have any questions, ask your instructor.

Learning Outcomes

Upon completion of this module, you will be able to:

1. List and describe the core competencies and cybersecurity controls set out by the NIST Cybersecurity Framework.
2. Describe insider threats to an organization and the necessary measures to counter such threats.
3. List and explain the best practices for ensuring the physical and environmental security of an organization's data and information systems.
4. Define and describe other concepts relevant to preventative best practices, including employee training, threat and vulnerability assessment, user account management, and access control.

Key Terms & Concepts

Listed below are some important key terms and concepts within this module.

- NIST Cybersecurity Framework
- Insider Threats
- Malware and Virus
- Network Segmentation
- Firewalls and Network Address Translation
- Wireless Network
- Remote Access
- Information Security Protection
- Supply Chain Management

Best Practice

The NIST Cybersecurity Framework is an internationally recognized standard; it provides a policy framework, identifying five core competencies that underpin any comprehensive cybersecurity policy.

Protect

Develop appropriate safeguards and policies to protect critical infrastructure services.

Identify

Identify the risks an organization faces within its business context; identify its available resources to create a risk management policy.

Detect

Develop policies to identify the occurrence of a cyber incident.

Respond

Create a strategy to take action once a cyber incident is discovered.

Recover

Develop procedures to recover from a cyber incident.

Best Practice

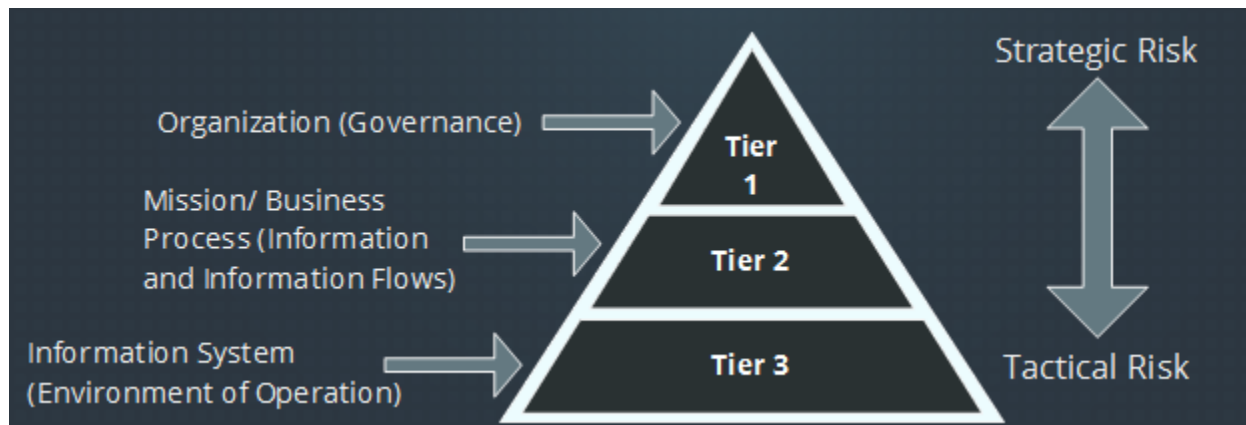
The Investment Industry Regulatory Organization of Canada's (IIROC's) "Cybersecurity Best Practices Guide" also provides a catalogue of cybersecurity controls that organizations can use to build their custom cybersecurity policy. IIROC standards include recommendations from different sectors such as

financial and industrial, and also from intelligence communities. The guide also considers national and international standards in developing a framework that most organizations can use as a reference point.

Cybersecurity Controls Recommended by NIST

An effective cybersecurity policy requires an interdisciplinary approach that draws on the experiences and input of different departments, including IT, executive, legal, HR and business.

Cybersecurity controls should manage risk at three levels: the organizational level, the mission/business processes level and the information system level. The tiered approach allows cybersecurity to be implemented across different tiers and facilitates intra- and inter-tier communication, with the shared objective of achieving the organization's cybersecurity goals.



These steps outline the approach that organizations should adopt to create an effective cybersecurity policy:

Governance Team

The executive needs to determine which departments, and which individuals within those departments, should compose the team; a team leader (such as CFO or CIO) should be appointed. The team's efforts should be documented and reported to a specialized committee or to the board itself, to ensure that the team addresses organization-wide concerns.

Current Inventory

Once a governance team is established, it should accurately inventory the organization's data and information system. The inventory should include the physical systems' location, as well as what information is on them and who has permission to access them. The objective is to classify and prioritize the organization's most critical data and systems.

Once an accurate inventory is created, the most secure controls need to be applied to the most valuable data for worksheets that an organization can use to stratify its data.

Risk Assessment

The next step is to orient cybersecurity efforts to the type of threats commonly faced by similar organizations. This helps create a risk assessment, which should contain details on typical threats and vulnerabilities. This is an ongoing process that should be updated regularly.

Target Profile

After completing the risk assessment, the organization should create a target profile. This entails determining the organization's cybersecurity goals, which should protect the organization and its stakeholders, including business partners and customers.

Determine and Prioritize Gaps

After completing a target profile, the organization should compare its current profile with the target profile to determine gaps and improvement opportunities in its cybersecurity program.

Implement Action Plan

A cybersecurity policy should be implemented, then tested and revised regularly to ensure that it works effectively in light of changing threats and business needs. With this approach, an organization can develop its roadmap to building a customized cybersecurity plan.

Insider Threats and Hiring Policies

An insider threat is defined as "a current or former employee, contractor or other business partner who has or had authorized access to an organization's network, systems or data, and intentionally exceeded or misused that access in a manner that negatively affected the confidentiality, integrity, or availability of [an organization's] information or computer systems."

Insiders pose certain risks to an organization and its business, intellectual property, trade secrets and infrastructure; compromising an organization's sensitive information can lead to financial, reputational and regulatory consequences. Disgruntled employees who feel underappreciated can also be prone to leaking private information for fraudulent reasons or for revenge.

Research demonstrates that employees who pose such risks often show some or all of these traits and behaviours:

- Introversion
- Lack of responsibility for own actions
- Excessive enthusiasm for working at odd hours or on the weekend
- Accessing the organization's network during holidays or vacation time
- Unnecessarily copying confidential material

Countermeasures to detect and monitor insider threats include:

Hiring Policies

Countermeasures for insider threats begin at the hiring stage. A background check can reveal an applicant's criminal background; requiring references from applicants also helps an organization detect and avoid troublesome people before they are hired.

Managing Workplace Issues

This entails an organization-wide effort, with input from human resources and senior management, to write and implement policies and procedures that create a desired organizational culture.

Newly hired employees should receive an orientation of the organization's structure, and they should be introduced to their team, colleagues and supervisors. They should also be informed that they can involve

HR in repairing and improving work relationships and other issues; at the same time, HR should be vigilant in anticipating and handling potential workplace problems.

Employee performance should be tracked to see if they are adjusting well. Those performing well should be recognized and awarded, and those performing inadequately should be coached. Most organizations also include company stocks in employees' compensation packages, to encourage employees to have a stake in the company's performance.

Continuing Education and Awareness Training

Employees should be trained to detect potential cybersecurity threats, especially concerning emails, web links and social media.

Technology

A recent study revealed that insider threats originate the most from the use of local access network (71 per cent), physical (28 per cent), and remote access (21 per cent). Certain security technologies can be deployed to minimize the risk of insider threats abusing the system. Common countermeasures include: data encryption, data loss prevention, data access monitoring, data access control identity and access management, and intrusion detection and prevention.

Physical and Environmental Security

Cybersecurity measures are not complete unless they entail the physical security of computer systems. Furthermore, organizations should have a recovery procedure in place for when computers are stolen or damaged by events such as employee error, natural disasters and power outages.

Here are some recommendations for ensuring physical and environmental security:

- a. **Clean Desktop:** Ensure that employees follow a "clean desktop" policy, whereby they lock up sensitive items before leaving work each day.
- b. **Only Legitimate Individuals Allowed:** Only allow people into the workspace who have a legitimate reason for being there.
- c. **Security Considerations with Screens:** Ensure that employees' screens are not visible to passersby.
- d. **Uninterruptible Power Supply:** Protect information systems from power outages by connecting them to an Uninterruptible Power Supply (UPS).
- e. **Backups:** Make backups regularly, to prevent total information loss if a natural disaster occurs. Backups are discussed in further detail later in this module.

Employees' Cybersecurity Training

To implement cybersecurity protocols effectively, organizations must train their employees in cybersecurity awareness. NIST's *Small Business Information Security Fundamentals (NISTIR 7621)* recommends teaching all employees the appropriate use of workplace technology, including computers and telephones.

After training, employees should sign a form to declare that they understand and will follow the organization's policies on technology use and cybersecurity controls.

Employees should be trained in the following areas:

Malware and Virus

Employees should be taught about malware, viruses and phishing scams, and they should also be warned against downloading unknown email attachments and emailing private financial information. Employees need to know that the best practice for dealing with a suspicious email is to inform the organization's IT security team and/or to call and confirm whether the sender actually sent the email.

Educating employees will not necessarily prevent all incidents, so employees should also be taught to remain calm and to report if malware is installed on their computers. They should be encouraged to contact IT immediately, so IT can run anti-malware on the machine and take appropriate remedial steps.

Employees should also be encouraged to backup critical information, in case their system is corrupted and their information cannot be retrieved.

Downloading Software from the Internet

Software and applications should be downloaded from trusted websites only. For security updates and legitimate software, trusted websites should be consulted directly.

Pop-up Windows and Other Hacker Tricks

Malware can also be downloaded by pressing "OK" on a popup window. Hackers also leave malicious code on USB drives, in places where employees frequent. Employees should be cautioned to avoid using unfamiliar USB drives, since connecting them to their computer can download malware to their machine.

Secure Web Surfing

Privileged or administrative rights should be reserved for IT and authorized staff only. Employees should know that it is possible to automatically install software if the internet is accessed from a privileged account.

Secure Online Business or Banking

Financial or banking tasks should be done through a secure web browser; a lock icon in the browser window indicates that the browser is secure. Employees should also be reminded to clear their browser history, temporary internet files and cookies after a session involving private financial information: this is so their browser does not carry important information if their system is hacked.

Not to Connect Unsecured Devices

Employees should be warned against connecting unsecure devices to the network.

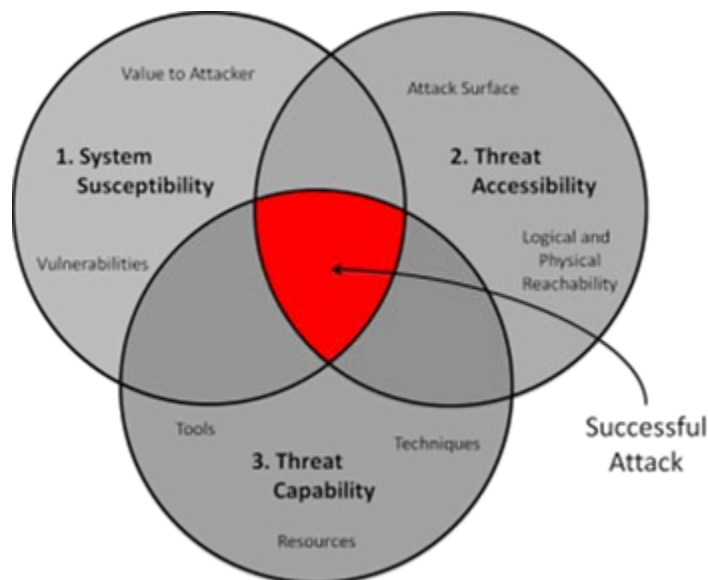
Strong Password Practice

Employees should be trained to keep secure passwords of at least eight random characters. The password should comprise numbers, letters and special characters and should be changed every 90 days. System settings should prevent employees from using their previous 15 passwords.

Assessing Threats and Vulnerabilities

Cybercriminals routinely exploit weaknesses in information systems to steal sensitive data. To keep ahead of the latest cyberthreat developments, organizations can subscribe to vulnerability intelligence reports. Organizations can also install and update vulnerability assessment tools, which can inform them of where and when updates or patches need to be made on computer systems and applications.

Users should update security on all new computers and new software; specific security update guidelines are available for commonly used operating systems (Microsoft, Apple, Sun, Unix, or Linux).



Network Security

Devices which are unknown, unauthorized or unpatched should not be permitted to access the network. The goal of network security is to strike a balance between security, usability and cost, while working within the information system of an organization.

Common Law: History

The best practices in network security are as follows:

- Network Segmentation
- Securing Remote Access
- Auditing Network Access
- Securing Wireless Network
- 802.1XPNAC
- Firewalls and Network Address Translation (NAT)

Network Segmentation

The first step in building a secure network is designing and segmenting the network. As noted earlier, additional network security comes at a higher cost. To keep costs lower without compromising security, it is therefore important to identify parts of the network that require high security and those that do not—this allows resources to be allocated efficiently.

Secondly, networks are generally more vulnerable at the edges, i.e. at points where they connect to other networks. Having a clear idea of a network's connection points between segments and to other networks allows security controls to be placed at appropriate points.

If an organization has multiple geographic locations, then each location must have its own network segment, with firewalls in place at connection points, to secure connections to the public internet. Even if an organization has private fibre lines between its locations, it should not be assumed that the link is secure.

Within one location, administrative and general-use computing systems should be separate from operations systems such as servers, databases and industrial command-and-control systems. Similarly, wireless networks—especially those that allow temporary users to connect while visiting the location—should be separate from the organization’s internal network segments.

Firewalls and Network Address Translation (NAT)

Once the network has been segmented, the access level required between the segments should be determined. Firewalls should be configured to mirror the appropriate level of access. IT employees, for example, may need specific access from the organization’s internal network, to configure and update the website. Similarly, all outbound traffic should be screened.

Some systems, such as in-store point of sale terminals, only run specific tasks. Accordingly, a firewall should block all outgoing traffic other than certain whitelisted locations that are specifically needed by the terminal. It is a good idea to use NAT to make sure private systems do not have a publicly visible address and can only communicate with the public internet using a NAT server. This prevents attackers from scanning a system for vulnerabilities.

801.1XPNAC

Once a network’s edges have been secured and only required traffic crosses those boundaries, the network segments should be secured. Modern networks are self-configuring by design: if a laptop is plugged into any wall jack in the building, the network can usually be accessed. However, this feature also means that anyone with physical access to the building can connect their laptop and access the network. Firewalls are not helpful here, as they only filter traffic at the edges of the network. Port-based Network Access Control (PNAC) uses a challenge-response authentication system, which cannot be easily forged, as it requires the supplicant (device trying to connect) to possess a valid client certificate or username/password before accessing the network.

Certain devices such as printers may not support 802.1X. It is also possible to add application layer extensions and behavioural analysis, to control which devices can access the network.

The organization can mandate all employees to install an application that reports to the authorization server the following information: the OS version, whether anti-malware software is running and the time of the last scan. If the application is not running or if the information it reports is concerning, the authorization server will deny access until the issue is resolved.

Malicious users and devices can be automatically detected through tasks such as scanning for open ports or OS fingerprinting. Fingerprinting can also be used to deny access to systems without requiring an application to be installed on the system itself.

Securing Wireless Network

Wireless networks present unique security challenges, as their access ports cannot be physically secured, and the devices that connect to them are often transient. Therefore, wireless devices should always be connected to their own network segment so that security policies can be applied to them appropriately. Wireless networks are easier to intercept, and this can allow attackers to eavesdrop on communication over the network. Therefore, it is critical to encrypt all communication over wireless networks.

One common policy applied by many organizations is to disable all HTTP (as opposed to secured HTTPS) traffic over wireless networks. Similarly, Wireless Protected Access 2 (WPA2) Enterprise can be used to authenticate devices trying to access the wireless network. WPA2 uses a challenge-response handshake, during which the actual password is never transmitted; hence, the password cannot be intercepted. WPA2 mandates the use of the more secure Advanced Encryption Standard (AES) algorithm to encrypt traffic.

The Enterprise version of WPA2 integrates with 802.1X servers, which is helpful because it can apply the security features of 802.1X.

Since wireless networks do not require a physical connection, it is often difficult to know which network it is connected to. Attackers can make a computer system connect to their access point by providing a stronger signal and then routing the traffic back to the real network. This way, they silently observe all the communication without the knowledge of the network or its administrators. This is often called the “man-in-the-middle” attack. Such attacks can be prevented, as wireless signals have a limited range of tens of meters.

Securing Remote Access

Working remotely (or telecommuting) is increasingly common. To secure remote network connections, a Virtual Private Network (VPN) is essential. A VPN client will establish an encrypted tunnel that connects the user’s computer system to the organization’s network. The tunnel will prevent the public network from reading or modifying the communications transmitted within the tunnel.

To use VPNs securely, the organization’s VPN policy must disallow split tunneling. Split tunneling occurs when a computer system can access a secured network segment through the tunnel, along with the public network. Split tunneling is problematic, as it allows an attacker to use an employee’s computer system as a bastion and access the secured network by routing traffic through that computer system. By disabling split tunneling, the computer is either connected to the VPN or to the unsecure public network, but not to both.

To ensure secure VPN connections, the network should only allow strong VPN passwords and multi-factor authentication. This will ensure that even if credentials are leaked, attackers will not be able to access the computer network through VPN credentials.

Auditing Network Access

No security solution is perfect, so organizations must remain vigilant in finding and correcting vulnerabilities. This entails regular audits of network access, including access from countries where the organization does not have a presence. In this regard, Dynamic Host Configuration Protocol (DHCP) logging, firewall logging and NAT logs should be enabled and audited. Every device that connects to the

network will need to connect to the DHCP server and, therefore, the logs will contain detailed information about which devices accessed the network.

Firewall logs will show all the remote devices that tried to communicate with the network, regardless of whether they succeeded or failed. Logs can show if hackers are attempting to attack, in which case security can be heightened. Logs will also show unusual connection patterns, even for successful connection attempts.

Similarly, NAT logs will show outgoing connections. If the database server tried to connect with an unknown domain, it means the server is compromised and someone is trying to steal data. Such audits are often the last line of defence, to prevent breaches not caught by other controls, and they are the primary way of detecting ongoing breaches.

Information Security Protection

Some best practices for securing computer systems include:

- a. Backup and Recovery
- b. Active Scanning
- c. Controlling Removable Storage Media
- d. Updates and Patches
- e. Securing Remote Access

Backup and Recovery

Systems should be backed up regularly and retained for an extended period, as malware can remain undetected for years in some cases. Backups should be kept in geographically diverse locations, isolated from the network, and should require unique credentials to access. Hence, if the primary data center is damaged or credentials are compromised, backups will not be at risk.

A common practice is to use third-party storage solutions that can automatically distribute backups across many data centers throughout multiple jurisdictions. Many organizations keep backups but do not check to see if the backups are valid.

Active Scanning

All workstations, servers and mobile devices connected to the company network should have anti-malware and anti-spyware software, and personal firewall solutions installed and active. Several vendors offer integrated solutions for personal and enterprise systems. These solutions are updated with fingerprints of the latest malware, and can prevent them from executing, even if other security measures fail.

Controlling Removable Storage Media

Modern networks are fast and inexpensive enough that there is rarely a need for using removable media such as USB thumb drives and DVDs. Many customers remove DVD drives and ensure through security policies that thumb drives are not used. This can be an important measure, as removable media bypass the network security described earlier. Network security tends to be one of the strongest barriers to the compromised systems, so anything that bypasses such controls is a concern.

Updates and Patches

It is critically important that the latest versions of the operating system, applications and drivers are used on all systems. Vendors regularly update software's known vulnerabilities; running outdated software means that not only are the systems vulnerable, but the exploits to attack those vulnerabilities are well known and easily available.

A common policy is to apply automated security updates outside business hours, when systems are idle. Both Windows and OSX operating systems (as well as Unix/Linux operating systems) have support for enabling automated updates during idle times. Using the techniques described earlier, in conjunction with OS fingerprinting, it is possible to automatically quarantine computers running outdated operating systems.

Securing Remote Access

All remote access to the organization's network must be secured. Many organizations allow flexible work arrangements for working remotely, and their cybersecurity policy should provide a secure way of doing so. To enable secure remote access, VPNs should be used to ensure all traffic flowing over public networks is encrypted. VPNs also allow remote access to be granted or revoked; the use of multi-factor authentication, to protect against compromised passwords; and tracking users' activity. VPN access logs should be retained and regularly audited to prevent and monitor unauthorized access or strange access patterns, such as connections at odd times of the day or from countries where the organization does not have a presence.

Information Security Protection

Many organizations allow employees to use their own laptops and smart phones for work, but there are risks associated with this practice. Employees may lose their devices or install unsecure applications. They may unintentionally disclose sensitive organizational information. They may also allow their family or friends to use their device and inadvertently access private company data.

Before allowing employees to use their own devices, organizations need to conduct a risk assessment. A robust "bring-your-own-device" (BYOD) policy should be in place, to mitigate risk in case there is a breach.

A BYOD policy should dictate which employees and which devices are permitted; the policy should also explain which services or information can be accessed and which are prohibited.

The organization needs to ensure that its data can only be accessed through a virtual desktop such as Citrix or VMware. The level of support that the IT department can offer to employees using their own devices should be decided in advance. Employees should be apprised of the potential disciplinary actions for not complying with the BYOD policy.

Network controls can be used to ensure that devices not running up-to-date operating systems or malware-scanning software are automatically quarantined. In addition, it is important to ensure that full-disc encryption is enabled on such devices, and that they can be remotely wiped just like any other device with access to the organization's sensitive systems.

User Account Management and Access Control

Cyberthreats have many shapes and forms, but all organizations face the threat of malicious insiders. Therefore, it is best to implement controls that allow an organization to limit and track the access each employee has to the organization's private data. User account management and access control ensures that each employee has a separate account, allowing employees' access and online activity to be tracked, controlled and monitored individually.

The first step is to implement a process to allow the organization to centrally manage all accounts. If an employee's credentials are compromised, their account can then be revoked and reissued centrally, blocking the employee's access to other systems and containing malware to one account.

Users should only be given access to systems and information that they need. The central account management system should be able to disable accounts of terminated employees, as they no longer need access.

Detailed user activity logs should be retained and periodically audited, to flag and investigate malicious activity. This will also help forensic post-breach analysis to quickly identify the source and extent of a breach. These activity logs should be stored securely so that only privileged users can access or modify them. Otherwise, attackers can hide their tracks and avoid detection by falsifying activity logs.

Asset Management

The following countermeasures help protect and manage an organization's assets:

- a. Organizations should ensure that all devices are tracked. Inventory control should be exercised, so organizations know which employee has which device. This can be done by maintaining an automatic asset inventory discovery tool, which can track all devices used by employees. New devices also must be entered into the system.
- b. Implement a mechanism for applying security policies, including automatic updates, to all devices and computer systems. If a device is reported lost or stolen, the inventory control system should be able to prevent it from connecting to the network. To this end, organizations can use DHCP server logging to detect an unauthorized attempted connection. Additionally, organizations should employ full-disk encryption and remote-wipe capabilities, to ensure that lost or stolen devices are not a security liability.
- c. Firewalls should be used to block unauthorized communication.
- d. Client-side certificates can be used to validate and authenticate systems and applications trying to access secured resources.

Supply Chain Management

Supply chain management refers to organizations managing their business relationships with third parties. These relationships pose certain cybersecurity risks. For example, if a supplier does not adhere to the purchasing organization's cybersecurity policy, it poses a risk to that organization and its customers, business and reputation. In recent years, most cyberattacks have been aimed at suppliers' information systems. Because of risks associated with suppliers, an organization's cybersecurity program is incomplete if it does not include a policy for managing these risks.

To manage relationships with suppliers, organizations should follow these steps:

1. Create a risk profile for each supplier, based on the sensitivity of data shared; the impact on business and reputation if that data is breached; the type and frequency of transactions; and the regulatory risks associated with the service provided. In addition, organizations should check each supplier's cybersecurity program and determine if it has been breached before.
2. Have a contact person within the organization who maintains knowledge of and compliance with reporting requirements, liaises with suppliers and senior management, ensures that a paper trail is maintained between the legal and contracting teams, and monitors the supplier's litigation or regulatory issues.
3. Ensure that the supplier is following the cybersecurity policies mandated in the contract. Depending on contractual terms, the organization may be allowed to test whether this is the case.

At a minimum, the organization should ensure that the supplier does the following:

- Encrypts its data
- Has a data loss prevention system
- Routinely conducts vulnerability and penetration testing
- Has an adequate incident response management plan

In case the supplier does not comply with the organization's cybersecurity policy, the organization should have mechanisms, such as contract clauses, for enforcing penalties or terminating the relationship.

Cyber Policy and Insurance

Comprehensive cyber insurance should indemnify an organization against all losses stemming from a cyber incident, including:

- Hiring a professional response team
- Notification costs
- Administrative and safeguard costs
- Litigation costs

Traditional insurance, however, does not cover all costs associated with cyber incidents; therefore it is best practice for an organization to carefully review its pre-existing insurance to determine which cyber costs would be covered, and purchase a policy that covers all cyber incident-related costs.

Essential Elements of a Data Security Policy

1. Data Privacy
2. Password Management
3. Internet Usage
4. Email Usage
5. Company-Owned Devices
6. Employee-Owned Mobile Devices
7. Social Media
8. Software Copyright and Licensing
9. Security Incident Reporting

Organizations should also check the exclusions that may come with cyber insurance. These exclusions are primarily based on industry classification. However, some of them can be removed based on the organization's pre-existing cybersecurity program, including whether their devices are encrypted and their applications/software are patched and updated.

It is best practice for organizations to review, update, and test their cybersecurity practices and to share them with trusted brokers, to ensure that insurance coverage proceeds smoothly in the event of a cyber incident.

Module Summary

In this module you have learned:

1. Cyberattacks are increasing in frequency and sophistication.
2. Cybercriminals do not discriminate on the basis of an organization's motives; targets can range from universities, to for-profit organizations, to hospitals.
3. Organizations need to implement cyber risk management frameworks and measures to minimize potential damage to the organization's finances, operations and reputation.
4. Organizations need to involve senior management and assemble the right people to achieve appropriate cybersecurity coverage. This requires an enterprise-wide effort, with input from different departments.
5. Organizations should monitor insider threats by applying technical controls and fostering a culture of inclusiveness.
6. Employees should be regularly trained to recognize cyberthreats.
7. Up-to-date technical controls for network security and information system protection should be applied, to ensure that malware cannot access an organization's network and sensitive information.
8. Legal counsel should be involved early on to address privacy and privilege concerns.

Knowledge Check

The following questions provide an opportunity for you to see what you remember and understand so far. Answer the questions to the best of your ability.

1. **An effective cybersecurity policy requires an interdisciplinary approach which draws the experiences and input of different departments: information technology (IT), executive, legal, human resources (HR), and business.**
 - a. True
 - b. False
2. **Countermeasures to detect and monitor insider threats include:**
 - a. Hiring Policies
 - b. Managing Workplaces Issues
 - c. Continuing Education and Awareness Training
 - d. Technology
 - e. All of the above
3. **Disgruntled employees who feel underappreciated and want to take revenge may also be prone to leaking private information for fraudulent reasons.**

- a. True
- b. False
- 4. **Having a clean desktop is a recommendation for physical and environmental security.**
 - a. True
 - b. False
- 5. **Employees should be trained with respect to malware and virus.**
 - a. True
 - b. False
- 6. **The goal of network security is to strike a balance between security, usability, and cost, while working with the information system of an organization.**
 - c. True
 - d. False
- 7. **Cyber incidents can be attributed to:**
 - a. Human Error
 - b. Operational Failure
 - c. Attacks by Cybercriminals
 - d. All of the above
- 8. **Securing remote access is a best practice in network security.**
 - a. True
 - b. False

Answers:

- 1. True
- 2. All of the above
- 3. True
- 4. True
- 5. True
- 6. True
- 7. All of the above
- 8. True

You have completed: Best Practices to Implement Prior to a Breach

Remember to check the timeline before you proceed to the next module to ensure you have completed any assignments as required. Check with your instructor if you have any questions.